

Unidade 3 — Segurança em APIs

Resumo estratégico para provas, entrevistas e desenvolvimento

1. Fundamentos de Segurança

Autenticação: verifica quem o usuário é.

Autorização: verifica o que o usuário pode acessar.

Hash (Message Digest)

Algoritmos hash transformam uma entrada em uma sequência de tamanho fixo e não reversível. São utilizados principalmente para armazenamento seguro de senhas.

Fluxo: Senha → Hash → Armazenamento.

Login → Hash da senha digitada → Comparação.

Exemplo popular: SHA-256.

Base64

Base64 NÃO é criptografia.

É apenas uma codificação usada para transformar dados binários em texto.

Pode ser decodificada facilmente.

2. Infraestrutura de Chaves Públicas (PKI)

Conjunto de tecnologias e processos utilizados para criação, distribuição e validação de certificados digitais.

Componentes principais

- ICP (Infraestrutura de Chaves Públicas)
- AC Raiz
- Autoridades Certificadoras (AC)
- Certificados Digitais

Criptografia Simétrica x Assimétrica

Simétrica

- Mesma chave para criptografar e descriptografar.
- Muito rápida.
- Exemplos: AES, DES.

Assimétrica

- Chave pública + chave privada.
- Mais segura para troca de chaves.
- Mais lenta.
- Exemplos: RSA e ECC.

Como funciona a Certificação Digital?

1. Gera-se uma chave simétrica.
2. O documento é criptografado com essa chave.
3. A chave simétrica é criptografada usando a chave pública do destinatário.
4. Apenas a chave privada correspondente consegue recuperar a chave simétrica.
5. A chave simétrica descriptografa o documento.

3. Autenticação HTTP

Principais mecanismos:

- Basic Authentication
- Digest Authentication
- Bearer Authentication

Basic Authentication

Usuário e senha são enviados codificados em Base64.

Deve ser utilizada apenas sobre HTTPS.

Header: Authorization: Basic ...

Digest Authentication

Cliente e servidor trocam hashes em vez da senha em texto. Mais segura que Basic Authentication.

Bearer Authentication

Modelo mais utilizado atualmente.

Após o login, o servidor gera um token.

O cliente envia esse token nas próximas requisições.

Header: Authorization: Bearer TOKEN

4. JWT (JSON Web Token)

Padrão RFC 7519 para autenticação baseada em tokens.

Estrutura:

HEADER.PAYLOAD.SIGNATURE

Header: algoritmo e tipo.

Payload: dados (claims).

Signature: garante integridade.

Claims importantes

- iss → emissor
- sub → usuário/entidade
- aud → destinatário
- exp → expiração
- iat → data de emissão

Importante:

JWT normalmente é utilizado como Bearer Token.

5. OAuth 2.0

Framework mais utilizado para autorização na internet.
Base para Login com Google, Facebook, GitHub e Microsoft.

Benefícios

- Evita compartilhamento de senha.
- Baseado em tokens.
- Compatível com Web, Mobile e Backend.
- Permite controle de escopos e permissões.

Papéis do OAuth

- Resource Owner
- Client Application
- Authorization Server
- Resource Server

Tipos de Grant

- Authorization Code (mais utilizado)
- Implicit
- Resource Owner Password Credentials
- Client Credentials

Access Token e Refresh Token

Access Token → usado para acessar recursos.

Refresh Token → usado para obter novos Access Tokens sem novo login.

6. CORS

Cross-Origin Resource Sharing.

Mecanismo que permite que um domínio acesse recursos hospedados em outro domínio.

Por padrão, navegadores seguem a política Same-Origin. O CORS flexibiliza essa regra de forma controlada.

Requisição Simples

GET, HEAD e POST.

O navegador verifica os cabeçalhos CORS da resposta.

Preflight Request

PUT, PATCH e DELETE.

Antes da requisição real, o navegador envia um OPTIONS.

Somente após autorização a operação é executada.

Headers importantes

Access-Control-Allow-Origin

Access-Control-Allow-Methods

Access-Control-Allow-Headers

Resumo para Entrevistas

- Hash $\neq$ Criptografia $\neq$ Base64.
- JWT é normalmente utilizado como Bearer Token.
- OAuth resolve autorização delegada (Login com Google).
- Access Token acessa recursos; Refresh Token renova acesso.
- HTTPS protege Basic Authentication.
- CORS controla acesso entre origens diferentes.
- PKI combina criptografia simétrica e assimétrica para segurança eficiente.